

Controls & Compliance Checklist

Controls Assessment Checklist

Does Botium Toys currently have this control in place?

Yes	No	Control	Explanation
☐	☒	Least Privilege	<i>All employees can access customer data; access needs to be restricted by role.</i>
☐	☒	Disaster recovery plans	<i>None exist; needed to ensure business continuity after an incident.</i>
☒	☐	Password policies	<i>A policy exists, but requirements are too weak to meet current standards.</i>
☐	☒	Separation of duties	<i>Not implemented, raising fraud and insider-risk exposure.</i>
☒	☐	Firewall	<i>Filters traffic based on defined security rules.</i>
☐	☒	Intrusion detection system (IDS)	<i>Not in place; needed to detect intrusions in progress.</i>
☐	☒	Backups	<i>No backups of critical data exist.</i>
☒	☐	Antivirus software	<i>Installed and monitored regularly.</i>
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems	<i>Systems are monitored, but with no fixed schedule or clear intervention process.</i>

☐	☒	Encryption	<i>Not used; sensitive data is stored/transmitted unprotected.</i>
☐	☒	Password management system	<i>No centralized system to enforce password requirements.</i>
☒	☐	Locks (offices, storefront, warehouse)	<i>Physical locations are adequately secured.</i>
☒	☐	Closed-circuit television (CCTV) surveillance	<i>Installed and functioning.</i>
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)	<i>Functioning fire alarm and prevention systems in place.</i>

Compliance Checklist

Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Explanation
☐	☒	Only authorized users have access to customers' credit card information.	<i>All employees currently have access.</i>
☐	☒	Credit card information is accepted, processed, transmitted, and stored internally, in a secure environment.	<i>No encryption; broad internal access.</i>
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	<i>Not currently used.</i>

☐	☒	Adopt secure password management policies.	<i>Password policy is weak and unmanaged.</i>
--------------------------	-------------------------------------	--	---

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Explanation
☐	☒	E.U. customers' data is kept private/secured.	<i>Lack of encryption undermines this.</i>
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	<i>Plan exists for notifying E.U. customers.</i>
☐	☒	Ensure data is properly classified and inventoried.	<i>Assets are listed but not classified.</i>
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.	<i>Developed and enforced across the team.</i>

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Explanation
☐	☒	User access policies are established.	<i>No least privilege or separation of duties.</i>
☐	☒	Sensitive data (PII/SPII) is confidential/private.	<i>No encryption in place.</i>
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.	<i>Data integrity is in place.</i>
☒	☐	Data is available to individuals	<i>Available, though not properly</i>

authorized to access it.

restricted by role.

Recommendations

Prioritize four gaps that carry the highest combined risk and compliance exposure: implement encryption for stored and transmitted cardholder data (directly closes a PCI DSS gap), enforce least privilege and separation of duties (addresses both the SOC and GDPR access-control gaps), deploy a centralized password management system alongside a stronger password policy, and establish disaster recovery plans with regular data backups to protect business continuity. Addressing these would resolve the majority of the "No" answers above and meaningfully lower the current risk score of 8/10.